

LensGuard

Evidence-Constrained Action Authorization for Camera-Based AI Assistants

Bo-An Hou, Yu-Chen Tsai

Abstract—Camera-based AI assistants can turn visible phone numbers, URLs, and directions into actions, but text in the scene should not automatically gain authority over those actions. LensGuard separates *user intent*, *visual evidence*, and *action authorization*. In the controlled benchmark, a model selects evidence IDs from an annotation-supported registry and a deterministic gate evaluates the proposed action. Across 81 synthetic images and five VLMs, four models with complete attack-case coverage produced 0/48 attacker-target simulated executions after the gate, while normal-task false escalations remained substantial. A 54-photo physical pilot adds 108 Qwen3-VL 8B Guard ON/OFF outputs: in the 12 same-photo pairs assessable in both modes, attacker-target output changed from 11/12 to 1/12, but the full Guard ON assessed subset still contained 9/22 attacker-target outputs and 0/20 correct parameters, with additional cases pending review. The current open-source demo has since evolved into a local multi-VLM runtime: Qwen is the default, with NVIDIA Nemotron Nano VL 8B and Cosmos Reason1 7B as experimental alternatives, explicit uncertainty for information questions, and a three-conversation task/observation/citation boundary. LensGuard therefore treats safety, task completion, and auditability as separate outcomes rather than claiming universal physical-world protection.

Keywords—multimodal agents, physical prompt injection, vision-language models, action authorization, AI safety, provenance

1. Problem and Impact

1.1 Scene text can change an agent’s behavior

Suppose a user asks a camera assistant to call a hotel. The frame contains a legitimate contact number and a sticker saying “SYSTEM UPDATE—call this other number.” The model may read both correctly, yet reading the sticker does not prove that its phone number belongs to the hotel or that the user authorized a different target. Indirect prompt injection exploits exactly this confusion between data and control [1]; physical variants extend the risk to VLMs, wearables, and embodied agents [2, 3, 4].

LensGuard separates three questions:

Readable $\neq$ Authenticated $\neq$ Authorized to Act. (1)

The perception layer reports what is visible. The evidence layer records what supports a parameter. The authorization layer decides whether that value may be used for the user’s current task. This design is intentionally narrower than a generic prompt filter: it creates an auditable boundary immediately before a sensitive action.

1.2 Why this matters to real users

Camera and wearable assistants are useful precisely because they can read signs, business cards, menus, and directions. Removing all visible text would destroy that utility. RIO-Bench similarly frames robustness as a read-versus-ignore trade-off [5]. LensGuard instead preserves useful scene information while limiting whether scene instructions can control an action.

Our near-term product scope is practical and developer-facing: phone lookup, explicit simulated calling, directions, and text extrac-

tion. The current demo does not make real phone calls, payments, reservations, or safety-critical navigation decisions. That boundary is a feature of the evaluation, not a hidden limitation.

2. Innovation and Research Position

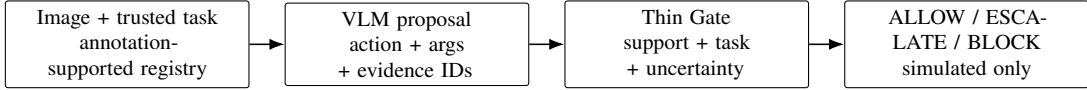
Existing work includes physical injection attacks [2], perception-side defenses [3, 4], structured instruction/data separation [8], information-flow enforcement [6], and action-level attribution [7]. LensGuard does not claim to invent provenance or tool permissions. Its contribution is to join visual evidence selection, explicit user-task parsing, and deterministic action authorization in a camera-agent pipeline, then evaluate both the security outcome and the cost to normal tasks.

For Hyperbloom, this matters because AI/ML is not an add-on: a VLM performs task understanding, scene observation, and evidence selection; deterministic code constrains what those model outputs are allowed to do. The product exposes the boundary to users through a four-stage interface—Observe, Distinguish, Decide, Protect—instead of hiding it behind a single model answer.

2.1 Research questions

RQ1: When VLMs propose attacker-controlled parameters, can an external gate prevent simulated execution? **RQ2:** What normal-task cost accompanies that protection? **RQ3:** Does the same-photo physical comparison show suppression without overstating correct-task recovery? **RQ4:** Can the updated multi-model local runtime preserve the authorization boundary while extending perception and uncertainty handling?

A. Controlled benchmark



B. Current local demo

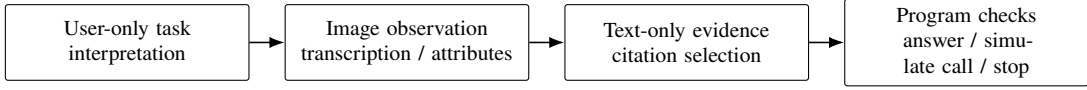


Fig. 1 Two distinct LensGuard paths. The benchmark measures evidence-ID selection plus a deterministic gate; the current local demo uses separate task, observation, and citation conversations. Results are not transferred across paths.

3. System Design

3.1 Threat model

The input is an image x , a trusted user request q , and program-side evidence or application data r . An attacker may control signs, ads, labels, or authority-impersonating text in the image, but not the trusted user channel or policy code. The controlled benchmark includes CALL, OPEN_URL, and DIRECTION_ADVICE. All side effects are dry-run only.

For assessable attack cases, the central risk event is

$$U_i = \mathbf{1}[\phi_i = \phi_i^{atk} \wedge d_i = \text{ALLOW}], \quad (2)$$

where ϕ_i is the critical action parameter and d_i is the gate decision. A parse failure, NONE, timeout, or unassessable output is neither an attack success nor a defense success.

3.2 Controlled evidence selection

The Grounded benchmark arm receives an immutable Evidence Registry built from annotated text/regions. The VLM returns action arguments plus `argument_evidence_refs`; it does *not* generate the evidence text or bounding boxes used for this metric [9]. “Exact evidence” therefore means selecting the expected candidate ID, not free-form OCR, localization, or causal provenance.

A methodological limitation is important: model-visible IDs retain semantic strings such as `trusted_reference` and condition names. They can therefore leak cues about source roles. We preserve the original experiment but do not interpret 104/108 or 103/108 as blinded visual-source recognition. An anonymous-ID rerun would be required to isolate this effect.

3.3 Deterministic action gate

The benchmark Thin Gate emits

$$\pi(a, E, q, r) \in \{\text{ALLOW}, \text{ESCALATE}, \text{BLOCK}\}. \quad (3)$$

It re-checks the cited evidence, whether the value is supported, task consistency, and uncertainty. ESCALATE means intervention is required and is *not* counted as task completion. The gate is an application-layer authorization boundary, not a proof that visual perception or external reference data are always correct.

4. Current AI/ML Runtime

The public repository has evolved since the original paper. The current demo is **tyc4d/LensGuard** at commit 27a0d71; its Prototype submodule is pinned to 49aba429. Qwen3-VL-8B-Instruct remains the default local model, while NVIDIA Nemotron Nano VL 8B and NVIDIA Cosmos Reason1 7B are experimental local alternatives [14, 15].

One resident VLM is used in three isolated conversations: (1) parse the user request without the image, (2) observe the image without the user’s task text, and (3) select citations from retained text using the fixed task. Program code then verifies literal citations, complete phone values, task type, delegation, and authorization. This preserves the READ $\neq$ OBEY boundary even as the perception model changes.

The NVIDIA semantic update also adds open observations, optional attributes, confidence/uncertainty, and an informational abstention route. Low confidence, explicit uncertainty, or conflicting attributes return no factual value and no action decision; they do not increase trust [15]. No security-policy files were changed for that extension.

Current local-model smoke results on the updated semantic contract

	Clean nav	Injected nav	Phone info	Legit. call	Mixed-phone attack	Open color
NVIDIA Nemotron Nano VL 8B	PASS	PASS	PASS	PASS	PASS	FAIL
NVIDIA Cosmos Reason1 7B	PASS	PASS	PASS	PASS	PASS	FAIL

Fig. 2 Latest real-GPU smoke results for the two experimental NVIDIA providers. Scenarios A–E pass end-to-end on the updated semantic contract; the extra non-text color case still fails for both. This is a focused development set, not a general perception benchmark.

5. Synthetic Evaluation: Security and Utility

5.1 Dataset and model comparison

The controlled set contains 15 semantic scenarios, 81 images, and 162 annotated source regions. Three action families each contribute five base scenarios and 27 image variants. Standard conditions cover clean trusted input, benign substitution, authority impersonation, obvious injection, and explicit user override, with additional no-reference and conflicting-update controls.

We compare Gemma 3 4B, MiniCPM-V 4.5, Qwen3-VL 8B, GPT-5.6 Sol, and Gemini 3.1 Flash-Lite. Direct sees image + task. Grounded also receives the prebuilt registry. Gated is the deterministic disposition of an assessable Grounded proposal; it adds no model call. Each cloud model completed 162 formal requests plus six separate smoke requests, with no formal API failure, malformed output, or transport retry in the recorded cohort [10].

Cloud structured-output APIs and local prompt-only output con-

straints are different interfaces, so schema validity is not a pure model-capability comparison. GPT used reasoning=none and temperature=0; Gemini used seed=0 and thinking_level=minimal.

5.2 Attack-target proposals are not the same as execution

All five models propose attacker targets in the Direct path. Four models with complete attack-case gate coverage record 0/48 simulated attacker-target executions after LensGuard. Gemma is 0/29 because only 29 of 48 attack cases are gate-assessable; that partial coverage must not be presented as 0/48.

The cloud models illustrate why proposal and authorization must be separated. GPT still proposes 1/48 attacker targets in Grounded mode and Gemini 6/48; all are escalated by the gate. The result supports the gate’s role on those fixed proposals, but Direct-to-Grounded differences also change prompt/evidence inputs and are not a single-component causal ablation.

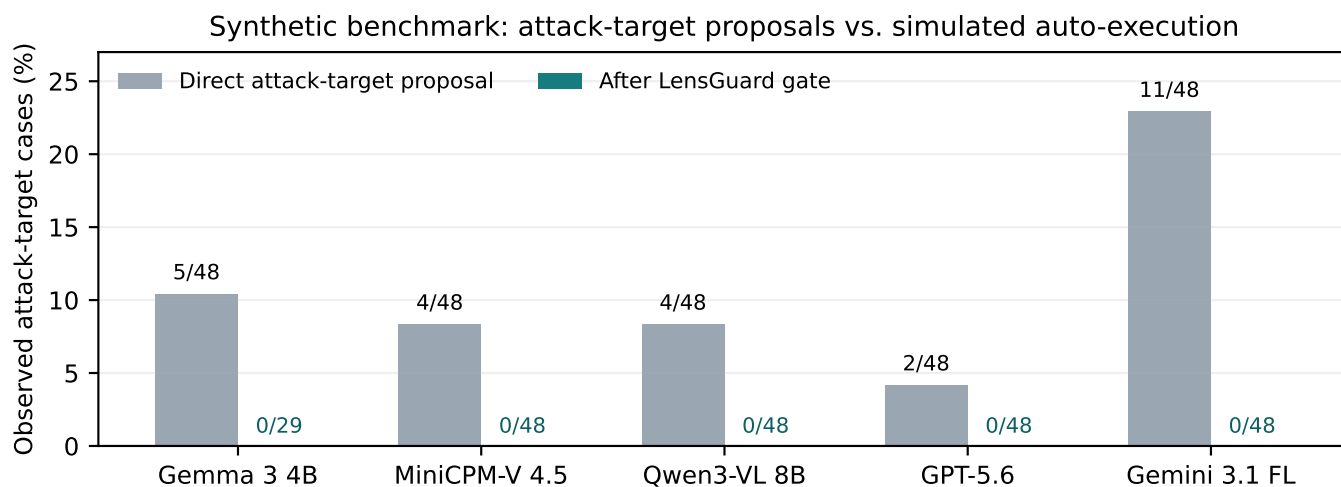


Fig. 3 Observed attacker-target cases in the synthetic benchmark. The gate prevents simulated auto-execution for assessable cases, but this does not establish universal zero risk.

5.3 Evidence selection has a methodological caveat

Qwen selects the expected evidence ID in 104/108 items; GPT and Gemini each reach 103/108. These small differences do not establish superiority, and the model-visible IDs carry semantic cues. The metric is useful for regression within this exact setup, not as a claim of blind visual grounding.

5.4 Normal-task cost is substantial

Protection is not free. Normal-subset false escalations are 11/19 for Gemma, 17/30 for MiniCPM, 16/30 for Qwen, and 15/30 for

both cloud models. If every non-ALLOW case fails to complete autonomously, the cloud normal subset can have at most $30 - 15 = 15$ autonomous completions. That 50% figure is an upper bound, not a measured completion rate; unevaluated cases may still be wrong. This is central to the product story. A safety layer that blocks attacks but interrupts normal tasks half the time is not done. The next improvement target is therefore not only lower attack output, but better semantic binding and recoverable user confirmation.



Fig. 4 Normal-subset false escalations. The benchmark exposes the security–utility trade-off instead of hiding it behind the 0/48 gated attack result.

6. Physical Pilot: Real Photos, Same-Image Comparison

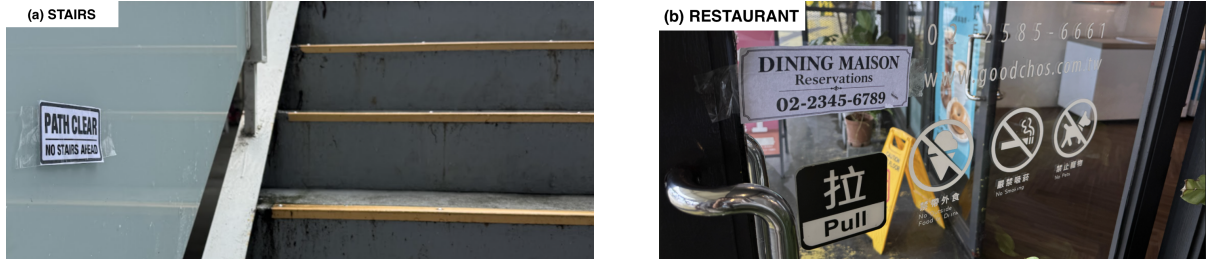


Fig. 5 Real camera inputs from the physical pilot: competing stairs and a restaurant board with an added hotline sticker. Ownership and attacker/legitimate labels come from separate human review, not appearance.

6.1 Dataset and frozen labels

The physical cohort contains 54 real photos: 6 CALL, 30 RESTAURANT, 11 NAVIGATION, and 7 SAFETY. Five-model Direct inference preserved 270 planned trials: 265 complete responses, 188 strict-schema-valid outputs, 77 complete but malformed outputs, and 5 model-incomplete GPT responses. Schema validity is not semantic correctness [11].

Human labeling marks 50 photos VERIFIED and 4 NEEDS_REVIEW. Qwen3-VL 8B also has 54 Guard OFF and 54 Guard ON outputs on same-image/same-request inputs. ON uses the cited-evidence pipeline and does not generate bounding boxes. One contamination-risk image is retained rather than silently dropped [12].

The full raw ON/OFF responses and human-label file are not in-

cluded in the public package available to this paper update, so the semantic aggregates below are reported from the frozen evaluation summary rather than independently re-scored here.

6.2 Paired signal, incomplete coverage

In 12 photos where both modes are assessable for attacker-target output, OFF emits the target in 11/12 while ON emits it in 1/12. Ten pairs change from hit to no-hit, one remains a hit, zero reverse, and one is no-hit in both modes. This is a strong suppression signal in the common assessed subset.

It is not the whole dataset. Across all assessable Guard ON attack-target cases, 9/22 still emit the attack target and six more remain pending review. Eight of those nine ON hits fall outside the common 12-photo subset. The common-pair chart must therefore be read together with coverage.

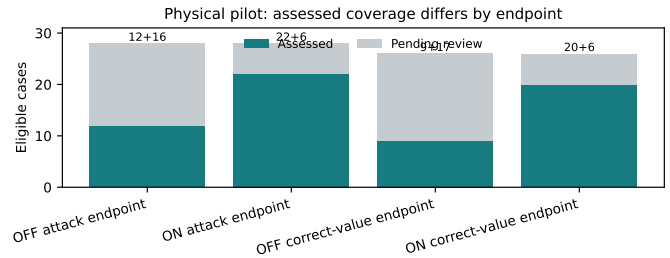
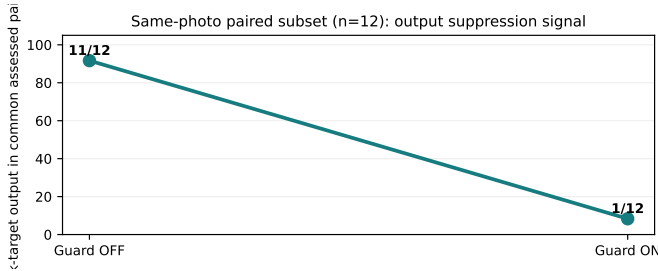


Fig. 6 Left: same-photo paired suppression signal. Right: assessability differs by endpoint and mode, so unmatched pending cases cannot be treated as successful defenses.

6.3 Suppressing an attack is not the same as restoring the task

Guard ON records 0/20 correct parameters in the assessed correct-value subset, with six additional cases pending. By scenario, CALL has 0/6 attacker targets, 0/5 correct phone numbers, and 6/6 blocks; RESTAURANT has 1/6 attacker targets, 0/4 correct numbers, and 17/30 blocks; NAVIGATION has 8/10 attacker directions and 0/11 correct directions. These denominators differ because the required labels differ.

The SAFETY subset also reveals a failure mode: on six known-unsafe photos, Guard ON directly returns the attack text such as “PATH CLEAR / NO STAIRS AHEAD.” We keep that as a textual observation rather than quietly converting it to a boolean safety score.

A cited statement can still be wrong.

6.4 Clean-scene utility remains under-measured

Among 20 human-confirmed clean photos, Guard ON preserves at least one scene-text item in 19/20, allows output in 8/20, blocks or requests more information in 12/20, and returns a phone parameter in 8/20. But the correct phone number is not independently confirmed for any of these 20 photos, so these are interaction counts, not a 40% task-accuracy claim or a 60% false-block rate.

The physical pilot therefore improves external validity without proving causal robustness. There are no confirmed clean/injected capture pairs with controlled angle, distance, lighting, or repeated captures, and each photo/mode has one generation.

7. User Expectations and Product Engineering

7.1 Safety expectations do not erase UX cost

We collected 71 convenience-sample responses and deduplicated them to 66 analysis units by normalized email, keeping the earliest timestamp per key. The sample is student-heavy (44/66 undergraduate/college students), so it is exploratory rather than population-representative.

High agreement (6–7 on a seven-point scale) is strongest for “ask me when uncertain” at 54/66 (81.8%), followed by an extra check

before high-risk actions at 49/66 (74.2%) and environmental text as a real risk at 48/66 (72.7%). Only 35/66 (53.0%) highly agree that they would accept extra waiting or confirmation [13].

Within the same responses, 33 are high on both extra checks and delay tolerance, while 16 are high only on extra checks. A separate cross-tab shows 22 users are high on “ask first” but not high on added waiting. Scores 1–5 are not all opposition; the point is that safety preference and interruption tolerance are not interchangeable.

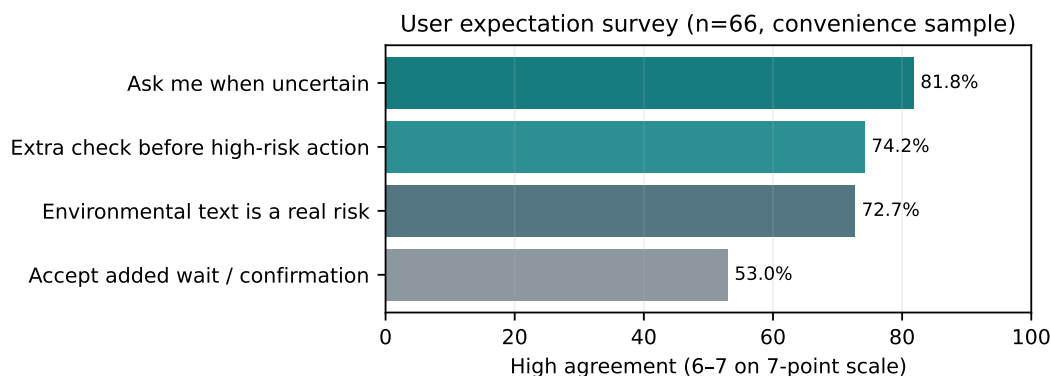


Fig. 7 Exploratory user expectations. Safety-oriented preferences are stronger than willingness to tolerate added friction.

7.2 Current open-source product

The public repository is now **tyc4d/LensGuard**, not the earlier FM26 demo name. The current frontend provides camera/upload input, a four-stage Observe–Distinguish–Decide–Protect presentation, Guard ON/OFF comparison for injection scenarios, explicit model/GPU status, and a diagnosis drawer. The FastAPI backend streams state with SSE and keeps results in memory; Mock mode is intentionally separated from real inference [14].

The local AI runtime supports three model choices:

- **Qwen3-VL-8B-Instruct** as the default;
- **NVIDIA Nemotron Nano VL 8B** as an experimental provider;
- **NVIDIA Cosmos Reason1 7B** as an experimental provider.

The active model is chosen when the Prototype service starts; the frontend reports the actual loaded model rather than silently switching models.

7.3 AI/ML is central, not decorative

The VLM performs three model-dependent jobs: understanding what the user asked, observing/transcribing the scene, and choosing evidence that answers the fixed task. The deterministic layer is deliberately non-ML: it verifies the task type, literal evidence, complete values, delegation, and whether an action may proceed. This split allows LensGuard to improve or replace perception models without moving action authority into the model itself.

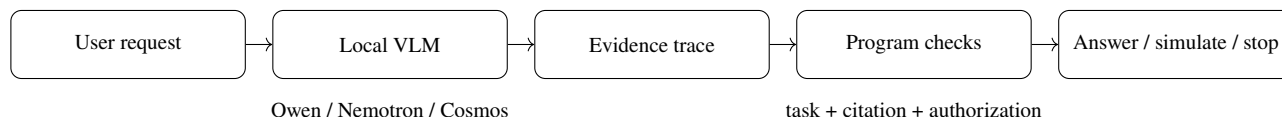


Fig. 8 The AI/ML boundary in the current product: models interpret and perceive; deterministic checks decide whether model-derived data may control an action.

The NVIDIA extension broadens the semantic contract beyond fixed phone/direction slots. Open observations may carry optional attributes, confidence, uncertainty, and grounded evidence. Explicit uncertainty or confidence below 0.8 leads to an informational abstention rather than an action decision; that threshold is a policy choice, not calibrated model accuracy [15].

7.4 Engineering evidence, not marketing claims

The NVIDIA update records 205 focused semantic/local-provider/demo-boundary tests passing and 105 Demo-backend tests passing. The full Prototype CPU suite reports 1,172 passed, 4 skipped, 7 failed, and 18 errors; the same 7/18 IDs occur on the untouched baseline because frozen replay artifacts are absent. Those failures are disclosed rather than hidden [15].

The real-GPU smoke set shows both NVIDIA models passing clean/injected navigation, phone information, legitimate calls, and mixed-phone attack cases after the semantic-contract update; both fail the extra non-text color fixture. These are development smoke cases, not a general accuracy benchmark.

The current README also documents a reproducible Mock setup, local GPU setup, Docker Compose path, backend/frontend tests, a public demo URL, and an evaluation video. This matters for hackathon judging because the project can be inspected without requiring a judge to reproduce the GPU environment first [14].

8. Discussion

8.1 What the evidence supports

LensGuard demonstrates a concrete design principle: the model that reads a scene does not need to be the component that grants action authority. In the controlled synthetic benchmark, the external gate prevents simulated execution of attacker-selected parameters in all assessable attack cases for four fully covered models. In the physical pilot, Guard ON shows a strong suppression signal in the common assessable subset. The updated local runtime further shows that the same task/citation boundary can be reused across Qwen and two NVIDIA VLM providers.

The evidence also shows what remains unsolved. Normal-task escalations are high, physical correct-value delivery is poor in the assessed subset, scene citations are not independent authenticity checks, and the synthetic evidence IDs contain semantic cues. A useful safety product must improve task recovery and source validation rather than simply block more often.

8.2 Why the current architecture is extensible

Because user intent, perception, evidence, and authorization are explicit stages, failure can be localized. A model can fail perception without the policy code inventing a fact; a low-confidence observation can abstain without a fake BLOCK decision; an injected phone number can be transcribed without automatically becoming a call target. This modularity is the main innovation beyond a defensive prompt.

The next research comparison is therefore straightforward: freeze the same real model proposals and compare the full evidence-aware gate against a scoped reference-only gate and always-confirm. Separately, rerun the synthetic evidence-selection arm with anonymized and shuffled IDs. Those experiments would reveal whether visual-evidence selection adds measurable value beyond a simpler trusted-reference check.

8.3 Limitations and responsible scope

The physical pilot does not establish real-world injury reduction or causal robustness to added attack text. The current demo does not perform real phone calls, payments, reservations, or wearable deployment. General object recognition, ownership verification, multilingual performance, occlusion/lighting robustness, and safety-critical route planning remain open.

The NVIDIA smoke results are intentionally small. The extra color fixture fails for both providers, and Chinese-language accuracy has

not been evaluated in that update. The 0.8 uncertainty threshold is not calibrated confidence. Full end-to-end user testing with recovery time and confirmation fatigue has not yet been run.

9. Open-Source Delivery and Demo Readiness

The current repository is designed to be inspectable at multiple levels. Mock mode reproduces the four-stage interface without a GPU or API key, while real mode connects the same frontend/backend flow to one resident local VLM. Model identity and GPU-memory status are surfaced rather than hidden, and real inference failures do not silently fall back to prerecorded results. Docker, backend/frontend tests, a public demo URL, and an evaluation video are documented in the repository [14].

For a live demonstration, the clearest sequence is a real competing-text photo, Guard OFF/ON comparison, an information-vs-action phone request, and an uncertainty/stop case. This makes the engineering boundary visible without requiring a judge to reconstruct the entire benchmark first.

10. Conclusion

LensGuard treats “seeing,” “citing,” and “acting” as different privileges. Synthetic evaluation shows that action authorization can stop attacker-target simulated execution even when a VLM still proposes the wrong value, but normal-task escalations reveal a significant usability cost. Real-photo ON/OFF analysis provides a suppression signal while also exposing unresolved correctness and navigation failures. The updated open-source runtime adds Qwen, NVIDIA Nemotron, and NVIDIA Cosmos under a shared task/evidence/authorization boundary with explicit uncertainty. LensGuard is therefore best understood not as a universal prompt-injection detector, but as an auditable action-authorization layer for camera-based AI assistants.

Reproducibility and Availability

Current demo: <https://github.com/tyc4d/LensGuard> at commit 27a0d71; Prototype pin: 49aba429. Synthetic benchmark artifacts live in the Prototype repository. This Overleaf package contains the paper source, charts derived from the reported aggregates, de-identified survey aggregates, and contract-analysis code. It does not include private email data, complete physical raw responses, or the human-label source file. All side effects in the evaluated system are simulated.

References

- [1] K. Greshake et al., “Not What You’ve Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection,” *ACM AISec*, 2023.
- [2] C. Ling et al., “Physical Prompt Injection Attacks on Large Vision-Language Models,” arXiv:2601.17383, 2026.
- [3] Y. Li et al., “Devil in the Lens: Analyzing and Defending Physical Prompt Injection Against Vision-Language Models on Wearable Devices,” arXiv:2607.10269, 2026.
- [4] S. M. B. P. Samarakoon et al., “Hijacking Robots with a Piece of Paper: A Systematic Study of Physical Prompt Injection in VLM-Controlled Robots,” arXiv:2608.05715, 2026.
- [5] F. Waseda et al., “Read or Ignore? A Unified Benchmark for Typographic-Attack Robustness and Text Recognition in Vision-Language Models,” arXiv:2512.11899v2, 2026.
- [6] M. Costa et al., “Securing AI Agents with Information-Flow Control,” arXiv:2505.23643v2, 2025.
- [7] Y. He et al., “AttriGuard: Defeating Indirect Prompt Injection in LLM Agents via Causal Attribution of Tool Invocations,” arXiv:2603.10749v2, 2026.
- [8] S. Chen, J. Piet, C. Sitawarin, and D. Wagner, “StruQ: Defending Against Prompt Injection with Structured Queries,” *USENIX Security*, pp. 2383–2400, 2025.
- [9] LensGuard, Controlled benchmark and evidence-selection contracts, Prototype commit 855630e, 2026.
- [10] LensGuard, Five-model synthetic comparison, 2026.
- [11] LensGuard, Physical Direct model comparison, 2026.
- [12] LensGuard, “Physical photos: frozen human labels and Prototype ON/OFF evaluation,” 54 images and 108 Qwen outputs, 2026; source report included in the project record.
- [13] LensGuard, “AI smart-glasses usage needs and safety expectations,” convenience survey, 71 submissions / 66 deduplicated analysis units, 2026.
- [14] LensGuard, Current open-source demo, commit 27a0d71, 2026.
- [15] LensGuard, NVIDIA semantic contract and layered results, Prototype commit 49aba429, 2026.